

- 1 Security Policy
 - 1.1 1. Introduction
 - 1.2 2. Security Governance
 - 1.2.1 2.1 Responsibility & Accountability
 - 1.2.2 2.2 Roles & Responsibilities
 - 1.3 3. Authentication & Access Control
 - 1.3.1 3.1 User Authentication
 - 1.3.2 3.2 Access Control Principles
 - 1.3.3 3.3 Session Management
 - 1.4 4. Data Protection
 - 1.4.1 4.1 Encryption Standards
 - 1.4.2 4.2 Data Classification
 - 1.4.3 4.3 Data Handling
 - 1.5 5. Code Security
 - 1.5.1 5.1 Secure Coding Standards
 - 1.5.2 5.2 Dependency Security
 - 1.5.3 5.3 Code Review Process
 - 1.6 6. Network & Infrastructure Security
 - 1.6.1 6.1 HTTPS/TLS
 - 1.6.2 6.2 Security Headers
 - 1.6.3 6.3 Rate Limiting
 - 1.7 7. Vulnerability Management
 - 1.7.1 7.1 Vulnerability Identification
 - 1.7.2 7.2 Vulnerability Assessment
 - 1.7.3 7.3 Remediation
 - 1.8 8. Incident Response
 - 1.8.1 8.1 Incident Definition
 - 1.8.2 8.2 Incident Response Procedure
 - 1.8.3 8.3 Notification Requirements
 - 1.8.4 8.4 Incident Communication
 - 1.9 9. Physical & Environmental Security
 - 1.9.1 9.1 Development Environment
 - 1.9.2 9.2 Data Center / Hosting
 - 1.10 10. Monitoring & Logging
 - 1.10.1 10.1 Security Logging
 - 1.10.2 10.2 Log Management
 - 1.10.3 10.3 Audit Trail
 - 1.11 11. Security Training
 - 1.11.1 11.1 Required Training
 - 1.11.2 11.2 Awareness Program
 - 1.12 12. Compliance & Auditing
 - 1.12.1 12.1 Compliance Requirements
 - 1.12.2 12.2 Regular Audits
 - 1.12.3 12.3 Audit Reporting
 - 1.13 13. Security Exceptions
 - 1.13.1 13.1 Exception Request Process
 - 1.13.2 13.2 Exception Review
 - 1.14 14. Third-Party Security
 - 1.14.1 14.1 Third-Party Assessment
 - 1.14.2 14.2 Data Sharing Agreements

- 1.15 15. Enforcement & Consequences
 - 1.15.1 15.1 Policy Violations
 - 1.15.2 15.2 Appeals Process
- 1.16 16. Policy Review & Updates
 - 1.16.1 16.1 Regular Reviews
 - 1.16.2 16.2 Policy Updates
- 1.17 17. Emergency Procedures
 - 1.17.1 17.1 Critical Incident Procedures
 - 1.17.2 17.2 Service Disruption
- 1.18 18. Document Information
 - 1.18.1 18.1 Version History
 - 1.18.2 18.2 Review Schedule
 - 1.18.3 18.3 Approval

1 Security Policy

Fuzzy Monster - QuizTimer4Zoom Application Effective Date: 2025-10-28

Classification: Internal - Sensitive **Company:** Fuzzy Monster **Domain:** fuzzy.monster

Based In: European Union

1.1 1. Introduction

This Security Policy establishes the security requirements, standards, and procedures for QuizTimer4Zoom. It applies to all developers, users, and systems that interact with the application.

The purpose is to: - Protect confidentiality, integrity, and availability of data - Ensure compliance with security best practices - Reduce risk of security incidents - Establish clear responsibilities and expectations - Enable rapid response to security threats

1.2 2. Security Governance

1.2.1 2.1 Responsibility & Accountability

Security Team: - Oversees all security matters - Reviews security incidents - Approves security exceptions - Updates security policies

Development Team: - Responsible for secure code - Implements security controls - Responds to security findings - Participates in security training

Management: - Allocates resources for security - Reviews security metrics - Approves security budget - Supports security culture

All Users: - Follow security policies - Report security issues - Complete required training - Use strong passwords

1.2.2 2.2 Roles & Responsibilities

Role	Responsibilities
Security Lead	Oversee all security, incident response, policy updates
Developer	Write secure code, fix vulnerabilities, security testing
DevOps	Secure infrastructure, deploy patches, monitor security
Product Manager	Security requirements in features, risk assessment
QA	Security testing, vulnerability scanning, reporting

1.3 3. Authentication & Access Control

1.3.1 3.1 User Authentication

Authentication Method: - Zoom OAuth 2.0 with PKCE - No username/password stored locally - Session-based access tokens

Authentication Requirements: - All users must authenticate via Zoom - No anonymous access allowed - Session timeout: 24 hours of inactivity - Required re-authentication for sensitive operations

Multi-Factor Authentication: - Zoom's MFA applies to user accounts - Additional MFA recommended for production access

1.3.2 3.2 Access Control Principles

Principle of Least Privilege: - Users have minimum necessary permissions - Access regularly reviewed and revoked - Separation of duties enforced - No shared accounts

Access Levels:

Level	Access	Who
User	Use application	All authenticated users
Developer	Read/modify code	Team members
Admin	Configure application	Authorized staff only
Root	System access	Emergency only, logged

1.3.3 3.3 Session Management

Session Security:

- Unique session ID per login
- HttpOnly cookie (JavaScript cannot access)
- Secure flag (HTTPS only)
- SameSite=Strict (CSRF prevention)

- 24-hour timeout
- Logout clears session immediately

Session Validation: - Session must be valid to access resources - Session replayed requests rejected - Concurrent sessions independent - Session fixation prevented

1.4 4. Data Protection

1.4.1 4.1 Encryption Standards

In Transit (TLS/SSL): - Minimum TLS 1.2 - Strong cipher suites required - Perfect forward secrecy enabled - Certificate valid and up-to-date

At Rest: - Sensitive data encrypted with AES-256 - Encryption keys managed separately - Regular key rotation

Key Management: - Keys stored securely, not in code - Access to keys limited - Key rotation policies enforced - Lost keys invalidate data

1.4.2 4.2 Data Classification

Public Data: - Application name, version - General documentation - Non-sensitive feature information

Internal Data: - Source code - Architecture documentation - Security procedures - Development timelines

Confidential Data: - Authentication tokens - API keys and secrets - User sessions - System credentials

Restricted Data: - Encryption keys - Vulnerability details (pre-patch) - Incident reports - Security assessments

1.4.3 4.3 Data Handling

Minimal Collection: - Only collect necessary data - No collection of unnecessary information - Privacy by design principle

Secure Storage: - Encrypted where practical - Access controlled - Regular backups - Secure deletion procedures

Secure Transmission: - Always use HTTPS - Encrypt sensitive data in transit - No plaintext credentials - Secure API communication

Retention & Deletion: - Minimum retention: as needed for function - Maximum retention: per data classification - Secure deletion procedures - Verified deletion

1.5 5. Code Security

1.5.1 5.1 Secure Coding Standards

Input Validation:

```
//  GOOD: Validate all inputs
const code = req.query.code;
if (!code || typeof code !== 'string' || code.length > 1000) {
  return res.status(400).json({ error: 'Invalid code' });
}
```

```
//  BAD: No validation
const code = req.query.code;
processCode(code); // Vulnerable!
```

Output Encoding:

```
//  GOOD: Encode output
res.json({ message: encodeURIComponent(userInput) });
```

```
//  BAD: Trust user input
res.json({ message: userInput }); // XSS risk!
```

Error Handling:

```
//  GOOD: Generic errors
catch (error) {
  console.error('Database error:', error); // Internal log
  res.status(500).json({ error: 'Internal server error' }); // Safe response
}
```

```
//  BAD: Information disclosure
catch (error) {
  res.status(500).json({ error: error.message }); // Leaks details!
}
```

Authentication:

```
//  GOOD: Verify tokens properly
const token = req.headers.authorization;
if (!token || !verifyToken(token)) {
  return res.status(401).json({ error: 'Unauthorized' });
}
```

```
//  BAD: Weak verification
if (req.headers.authorization) { // Just checking presence!
  proceed();
}
```

1.5.2 5.2 Dependency Security

Dependency Selection: - Use well-maintained packages - Review security history - Verify authenticity - Check license compatibility

Dependency Updates: - Weekly security scan - Monthly updates - Critical: patch within 24 hours - Test all updates before deployment

Prohibited Packages: - Packages with unpatched critical vulnerabilities - Abandoned/unmaintained packages - Packages that use unsafe cryptography - Packages that violate license requirements

1.5.3 5.3 Code Review Process

Mandatory Code Review: - All code changes reviewed by second developer - Security-critical code reviewed by security team - Review happens before merge - Automated checks must pass

Review Checklist: - ☐ No hardcoded secrets - ☐ Input validation present - ☐ Error handling secure - ☐ No sensitive logging - ☐ Proper authentication checks - ☐ Authorization verified - ☐ No SQL injection risks - ☐ No XSS vulnerabilities - ☐ No CSRF vulnerabilities - ☐ Cryptography correct

1.6 6. Network & Infrastructure Security

1.6.1 6.1 HTTPS/TLS

Requirement: All traffic must be encrypted

- Enforce HTTPS redirect
- HSTS header enabled
- TLS 1.2 minimum
- Strong ciphers only
- Valid certificates
- Certificate auto-renewal

Implementation: - Automatic HTTP → HTTPS redirect - Strict-Transport-Security header set - Certificate from trusted CA - Perfect forward secrecy enabled

1.6.2 6.2 Security Headers

Helmet.js Configuration:

Header	Purpose	Value
X-Content-Type-Options	Prevent MIME sniffing	nosniff
X-Frame-Options	Prevent clickjacking	DENY
X-XSS-Protection	Enable XSS filter	1; mode=block
Content-Security-Policy	Prevent injection	default-src 'self'

Header	Purpose	Value
Strict-Transport-Security	Enforce HTTPS	max-age=31536000
Referrer-Policy	Control referrer	strict-origin-when-cross-origin

1.6.3 6.3 Rate Limiting

Purpose: Prevent brute force and DoS attacks

Configuration:

Authentication endpoints: 5 requests per 5 minutes per IP

General API endpoints: 100 requests per 15 minutes per IP

Static files: 1000 requests per hour per IP

Response: - 429 Too Many Requests status - Clear retry-after header - IP temporary block after threshold

1.7 7. Vulnerability Management

1.7.1 7.1 Vulnerability Identification

Sources: - Automated scanning (npm audit, Snyk) - Code review findings - Security testing (SAST/DAST) - Penetration testing - Third-party disclosure - Public vulnerability databases

Scanning Frequency: - Automated: Continuous (per commit) - Manual: Weekly - Quarterly comprehensive scan - Annual third-party test

1.7.2 7.2 Vulnerability Assessment

CVSS Scoring:

Critical: 9.0-10.0 → Patch within 24 hours

High: 7.0-8.9 → Patch within 7 days

Medium: 4.0-6.9 → Patch within 30 days

Low: 0.1-3.9 → Patch in next release

Assessment Process: 1. Verify vulnerability is real 2. Assess impact on our system 3. Check exploitability 4. Determine patch availability 5. Plan remediation timeline

1.7.3 7.3 Remediation

For Internal Vulnerabilities: 1. Create fix immediately 2. Test thoroughly 3. Code review fix 4. Deploy to production 5. Verify fix 6. Document in changelog

For Dependency Vulnerabilities: 1. Update package 2. Run full test suite 3. Verify fix doesn't break functionality 4. Deploy 5. Monitor for issues 6. Document update

For Unpatched Vulnerabilities: 1. Document mitigation 2. Compensating controls 3. Regular reassessment 4. Timeline for patching 5. Alternative package evaluation

1.8 8. Incident Response

1.8.1 8.1 Incident Definition

An incident is any event that: - Breaches confidentiality (unauthorized access) - Compromises integrity (unauthorized change) - Disrupts availability (denial of service) - Violates policy or law

Examples: - Unauthorized access attempt - Successful intrusion - Malware infection - Data breach - Service unavailability - Security misconfiguration

1.8.2 8.2 Incident Response Procedure

Phase 1: Detection & Reporting

Anyone → Report → Security Team → Confirm Incident
Timeframe: Immediate

Phase 2: Initial Response (1 hour) - Confirm incident - Assess severity - Assemble response team - Gather evidence - Notify stakeholders

Phase 3: Containment (4 hours) - Isolate affected systems - Stop ongoing attack - Preserve evidence - Monitor for spread - Brief leadership

Phase 4: Investigation (1 day) - Root cause analysis - Determine impact - Assess data exposed - Identify lessons learned - Plan fix

Phase 5: Remediation (ongoing) - Implement fix - Test fix - Deploy to production - Verify effectiveness - Update procedures

Phase 6: Recovery - Restore normal operations - Verify system integrity - Test all functionality - Remove temporary measures

Phase 7: Post-Incident - Complete root cause analysis - Update security measures - Train staff - Update documentation - Share lessons learned

1.8.3 8.3 Notification Requirements

Internal Notification: - Report within 1 hour of detection - Update leadership every 4 hours - Daily status updates

Regulatory Notification: - Legal in 24 hours if legal implications - Zoom in 24 hours if app marketplace impact - Users/affected parties within 72 hours (GDPR requirement)

Public Notification: - Press release if major incident - Transparency about what happened - What we're doing to fix it - What users should do

1.8.4 8.4 Incident Communication

Template:

INCIDENT REPORT [ID: INC-2025-001]

Severity: Critical

Detected: [Time]

Contained: [Time]

Resolved: [Time]

Summary: Brief description

Impact:

- Systems affected
- Users affected
- Data exposed
- Duration of incident

Root Cause: What happened

Timeline:

- T+0: Detection
- T+30min: Contained
- T+4hrs: Fixed
- T+24hrs: Root cause identified

Resolution:

- What we did to fix it
- Preventive measures
- Monitoring implemented

Lessons Learned:

- What we learned
 - What we're changing
 - Training completed
-

1.9 9. Physical & Environmental Security

1.9.1 9.1 Development Environment

Workstation Security: - Operating system patches current - Antivirus/anti-malware active - Firewall enabled - Full disk encryption - No unauthorized software - Clean desk policy

Network Security: - WiFi WPA3 encryption - VPN required for remote access - No public WiFi for development - Firewalls enabled on all systems

Physical Access: - Workstations locked when unattended - No shoulder surfing of screens - No cameras in development areas - Clean desk policy for sensitive data

1.9.2 9.2 Data Center / Hosting

Infrastructure Security: - Secure data center with access controls - Environmental controls (power, cooling) - Fire suppression systems - Disaster recovery procedures - Backup power systems - Redundancy for critical systems

1.10 10. Monitoring & Logging

1.10.1 10.1 Security Logging

What We Log: - Authentication attempts (successful and failed) - Authorization failures - Data access - Configuration changes - Security events - Errors and exceptions

What We DON'T Log: - Passwords - API keys - Authentication tokens - Session IDs - Personally identifiable information - Credit card data

1.10.2 10.2 Log Management

Log Retention: - Development: 7 days - Staging: 30 days - Production: 90 days - Security incidents: 1 year - Legal holds: As required

Log Protection: - Logs encrypted in transit and at rest - Access controlled - Immutable records - Regular backups - Secure deletion

Log Monitoring: - Automated alerts for suspicious activity - Regular log reviews - Anomaly detection - Trending analysis

1.10.3 10.3 Audit Trail

Maintained Records: - Git commit history with signatures - Deployment logs with timestamps - Change management approvals - Access logs with user identification - Security event timeline

1.11 11. Security Training

1.11.1 11.1 Required Training

Initial Training (before access): - Security policy overview - Password security - Social engineering awareness - Data protection practices - Incident reporting

Annual Training: - SSDLC fundamentals - Secure coding practices - Security vulnerabilities - Incident response procedures - Privacy and compliance

Role-Specific Training: - Developers: Advanced security coding - DevOps: Infrastructure security - Security team: Advanced threat analysis

1.11.2 11.2 Awareness Program

Monthly Updates: - Security newsletter - New vulnerability announcements - Best practices tips - Incident case studies - Training opportunities

Phishing Awareness: - Simulated phishing campaigns - User education - Reporting procedures - Consequences training

1.12 12. Compliance & Auditing

1.12.1 12.1 Compliance Requirements

Standards & Frameworks: - OWASP Top 10 compliance - CWE mitigation - NIST Cybersecurity Framework - GDPR (for EU users) - CCPA (for California users) - Zoom Marketplace requirements

1.12.2 12.2 Regular Audits

Frequency: - Weekly: Automated scanning - Monthly: Manual security review - Quarterly: Security testing - Annually: Comprehensive audit

Audit Scope: - Code security - Infrastructure security - Access controls - Data protection - Incident response capability - Compliance status

1.12.3 12.3 Audit Reporting

Findings Reported: - Critical issues immediately - High/medium issues within 1 week - Low issues in monthly report - Metrics in quarterly review

Evidence Retention: - Scan reports archived - Finding remediation documented - Verification of fixes - Improvement tracking

1.13 13. Security Exceptions

1.13.1 13.1 Exception Request Process

Request Required For: - Disabling security controls - Using unpatched software - Storing unencrypted sensitive data - Exceeding access levels - Deviating from security standards

Approval Required: - Security team sign-off - Business justification - Risk assessment - Compensating controls - Time-limited authorization

Documentation: - Exception details - Risk assessment - Compensating measures - Approval signatures - Review schedule

1.13.2 13.2 Exception Review

Frequency: - Quarterly review of all exceptions - Reapproval required annually - Immediate review if incident occurs - Removal when no longer needed

1.14 14. Third-Party Security

1.14.1 14.1 Third-Party Assessment

Before Using Third-Party Service: - Security assessment - Data access review - Compliance verification - Incident response capability - Contract review

Ongoing Management: - Regular security reviews - Compliance verification - Incident notification requirements - Performance monitoring - Annual re-assessment

1.14.2 14.2 Data Sharing Agreements

Required Elements: - Data classification - Permitted uses - Security requirements - Breach notification - Data deletion requirements - Subcontracting restrictions - Audit rights

1.15 15. Enforcement & Consequences

1.15.1 15.1 Policy Violations

Investigation Process: 1. Report violation 2. Gather evidence 3. Interview involved parties 4. Determine severity 5. Take action 6. Document outcome

Consequences: - **Severe Violations:** Immediate suspension/termination - **Serious Violations:** Suspension, retraining, monitoring - **Minor Violations:** Warning, retraining, plan - **Accidental:** Training, monitoring, prevention

1.15.2 15.2 Appeals Process

Right to Appeal: - Violation determination - Consequence severity - Investigation findings

Appeal Process: 1. Written appeal within 10 days 2. Management review 3. Additional investigation if needed 4. Written decision 5. Final determination

1.16 16. Policy Review & Updates

1.16.1 16.1 Regular Reviews

Review Schedule: - Quarterly: Effectiveness review - Annually: Complete policy review
- As needed: Urgent updates

Review Process: - Gather feedback from team - Assess effectiveness - Consider lessons learned - Update for new threats - Industry best practices review

1.16.2 16.2 Policy Updates

Update Triggers: - New vulnerability types - Regulatory changes - Incident lessons learned - Technology changes - Best practice evolution

Communication of Changes: - Written notification - Training on changes - FAQ document - Transition period (if major change)

1.17 17. Emergency Procedures

1.17.1 17.1 Critical Incident Procedures

In Case of Major Breach: 1. Activate incident response team 2. Isolate affected systems (within 1 hour) 3. Preserve evidence (forensics) 4. Begin investigation (immediately) 5. Brief leadership (within 2 hours) 6. Notify required parties (within 24 hours) 7. Implement fix (ongoing) 8. Restore systems (once safe) 9. Communicate findings (transparency)

1.17.2 17.2 Service Disruption

If Service Becomes Unavailable: 1. Alert response team 2. Assess impact 3. Attempt diagnosis 4. Implement workaround 5. Communicate to users 6. Fix issue 7. Restore service 8. Post-mortem analysis

1.18 18. Document Information

1.18.1 18.1 Version History

Version	Date	Changes
1.0	2025-10-28	Initial security policy

1.18.2 18.2 Review Schedule

- **Next Review:** 2026-10-28

- **Review Frequency:** Annually
- **Responsible Party:** Security Lead

1.18.3 18.3 Approval

Policy Approved By: - Development Lead - Security Lead - Management

Date Approved: 2025-10-28

For questions regarding this Security Policy, contact: - Security Team:
security@fuzzy.monster - **Incident Response:** security@fuzzy.monster (use subject:
“SECURITY INCIDENT”) - **General Contact:** info@fuzzy.monster - **Website:**
<https://fuzzy.monster>

This policy is classified as Internal - Sensitive and should not be shared outside the organization without authorization.